Recommended Settings for using ZAP

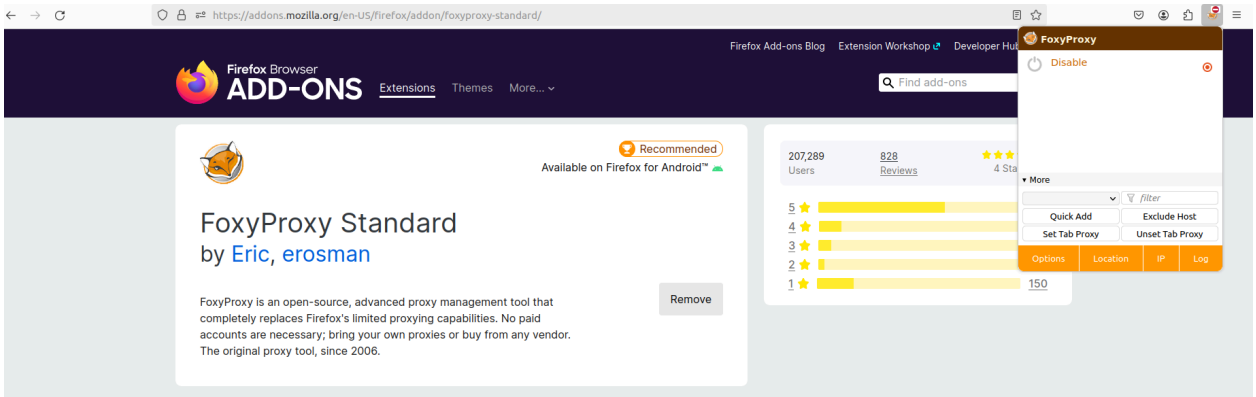
Introduction

When using ZAP we recommend some settings to be done beforehand to have a smooth lab experience. To that extent below sections will guide you step-by-step through those settings.

Step-1: FoxyProxy extension setup

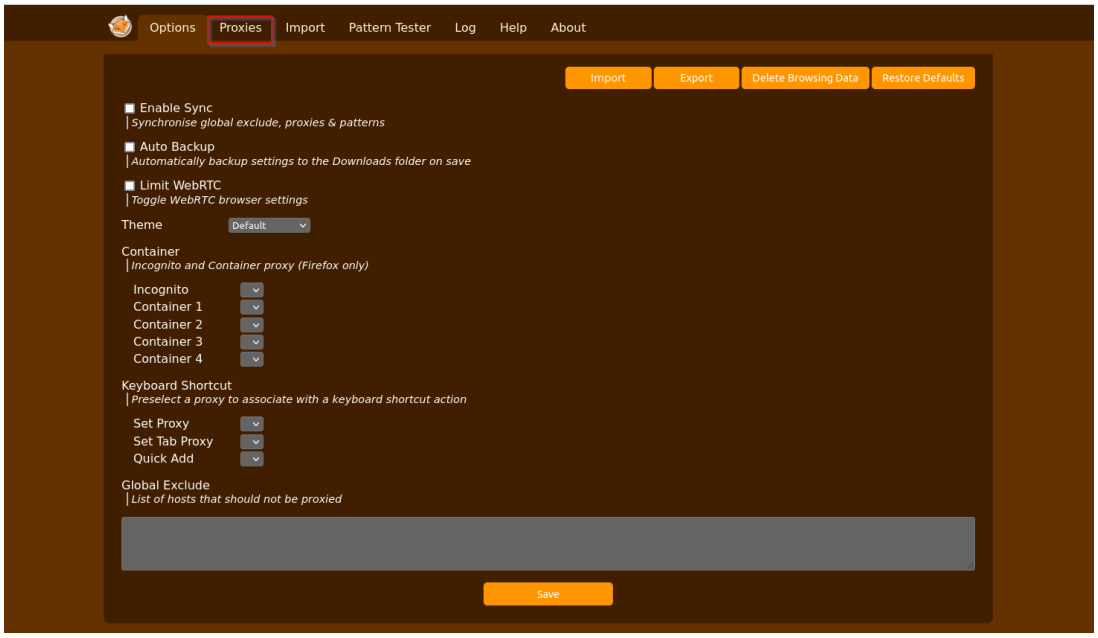
To analyze traffic and also to change GET/POST requests before they hit the server, one needs to capture the traffic being sent by the browser. FoxyProxy will help with that. It is an extension pack for browsers, easily available on the browser extension marketplace. It just directs all the http and https traffic of browser to some service/process configured on a specific IP:Port

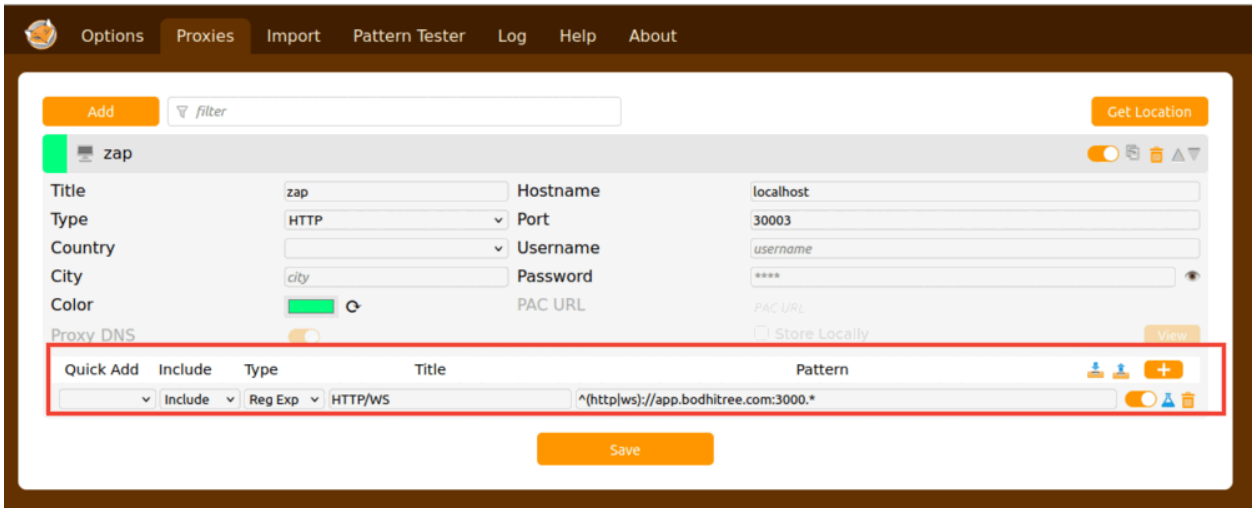
- To install FoxyProxy extension pack go to:
    - **Google Chrome: [Chrome-web-store]**
    - **Mozilla Firefox: [Mozilla-addons]**
- From here onwards we are taking Mozilla Firefox as reference, the settings for Google Chrome remain the same.
- Once you install the extension pack, you can verify installation by clicking on the puzzle piece icon in the top bar of the browser.



- We need to tell foxyproxy where to send the browser traffic to (this would be to our ZAP service). Further we do not want to send all browser traffic, it will make it difficult to analyze. We only want to send traffic to the website of interest. Assuming ZAP is running locally and say listening on port 30003. Further assuming the website of interest is also running locally and is on port 30000. We can specify all this in foxyproxy as below. See figure. Click on extensions, then foxyproxy, then options, then proxies tab. Click on “Add” and fill the form as shown. Further click on “+” and select/enter the same text as shown in the figure where title, hostname etc appear. Under pattern, be sure to enter

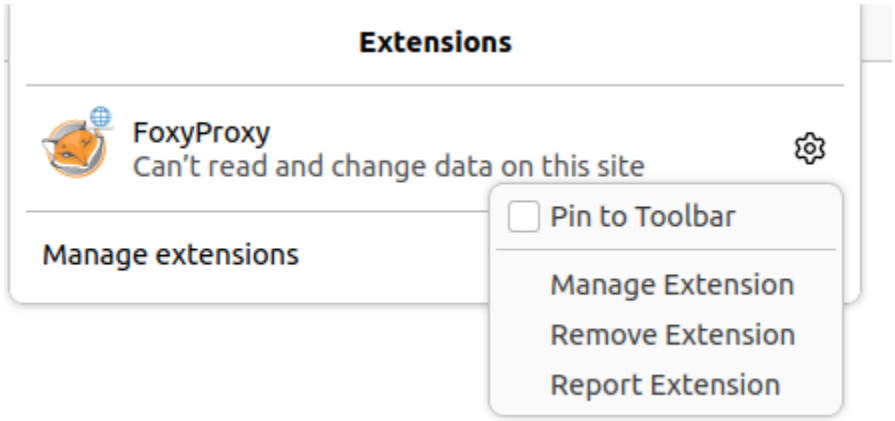
^(http|ws)://websec-bodhi.duckdns.org:30000/.* (instead of .... app.bodhitree...). This is the website of interest, which we will explore.

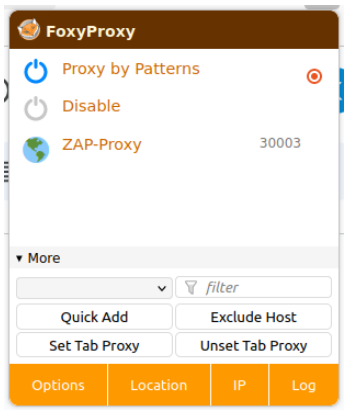




- You should see FoxyProxy under extensions and for convenience, you can also pin the foxyproxy icon to the top bar, by clicking on settings and then check the box Pin to toolbar.

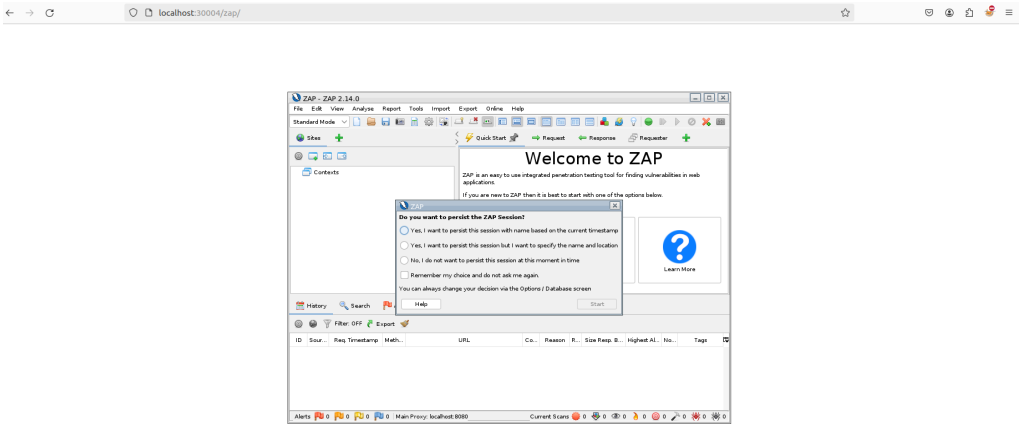
Clicking on Foxyproxy icon should show you “Proxy by Patterns”, enable it i.e. red dot against it.



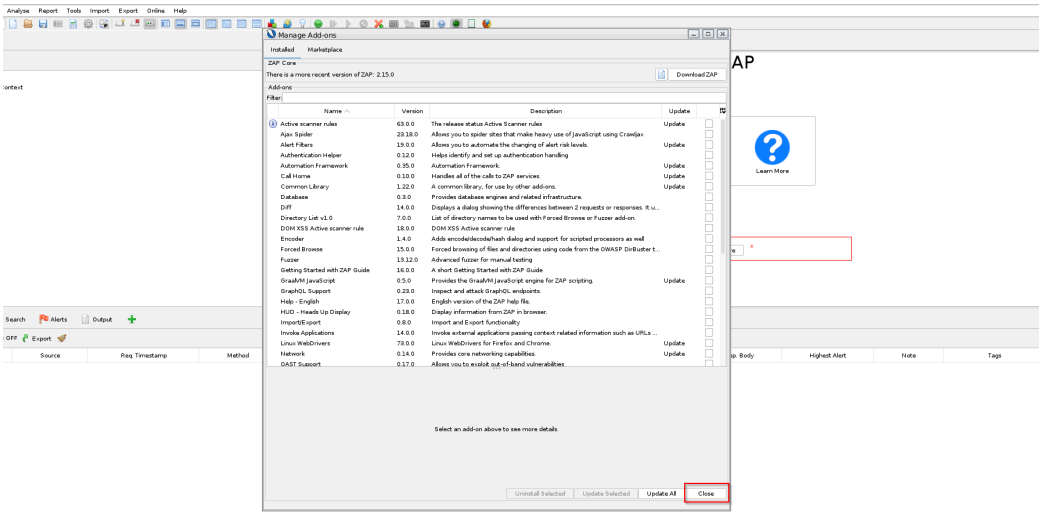


Step-2: ZAP Setup

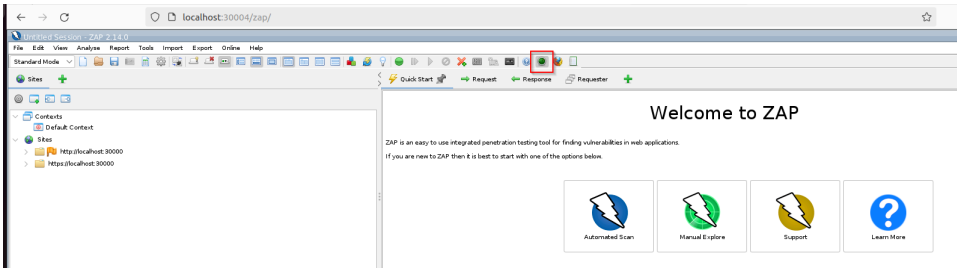
Instead of you having to install ZAP, as part of our cLab app, we have provided you with a container with ZAP installed. Note: ZAP is not running directly on your local host, it is running in a container launched by our clab app. You can however access it via a local browser i.e. browser running on your local host. To access the web interface of ZAP, visit “http://localhost:30004/zap/”. Note the ZAP application may take up to 2 minutes to start. In the meantime it may see “unable to connect” or blank screen or no connection etc, but just wait a while. Once the application is loaded, you should see a window like below



- Select “No, I do not want to persist ...” option and then press on “start”. You will be given a new popup window asking you to update as shown in the image below. Press on “Cancel”, **DO NOT UPDATE** , since it may cause autograders to fail.

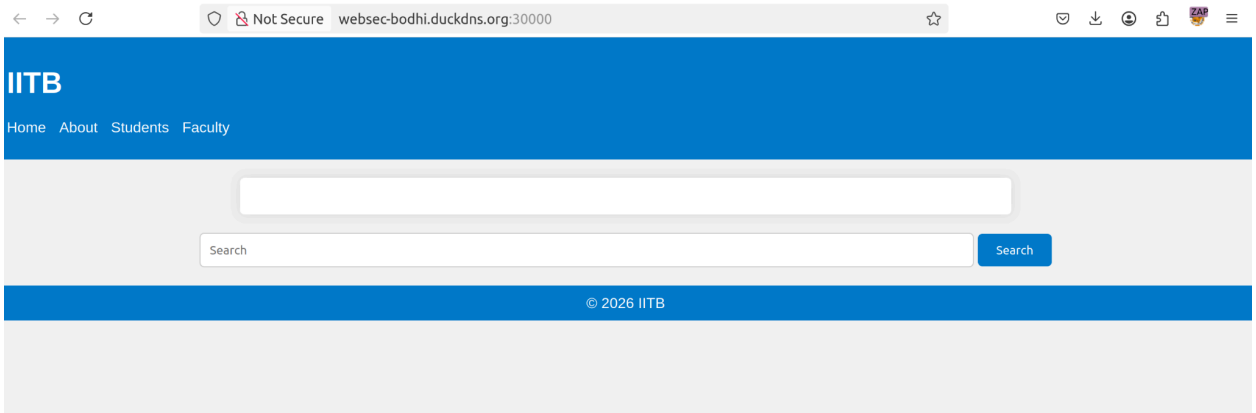


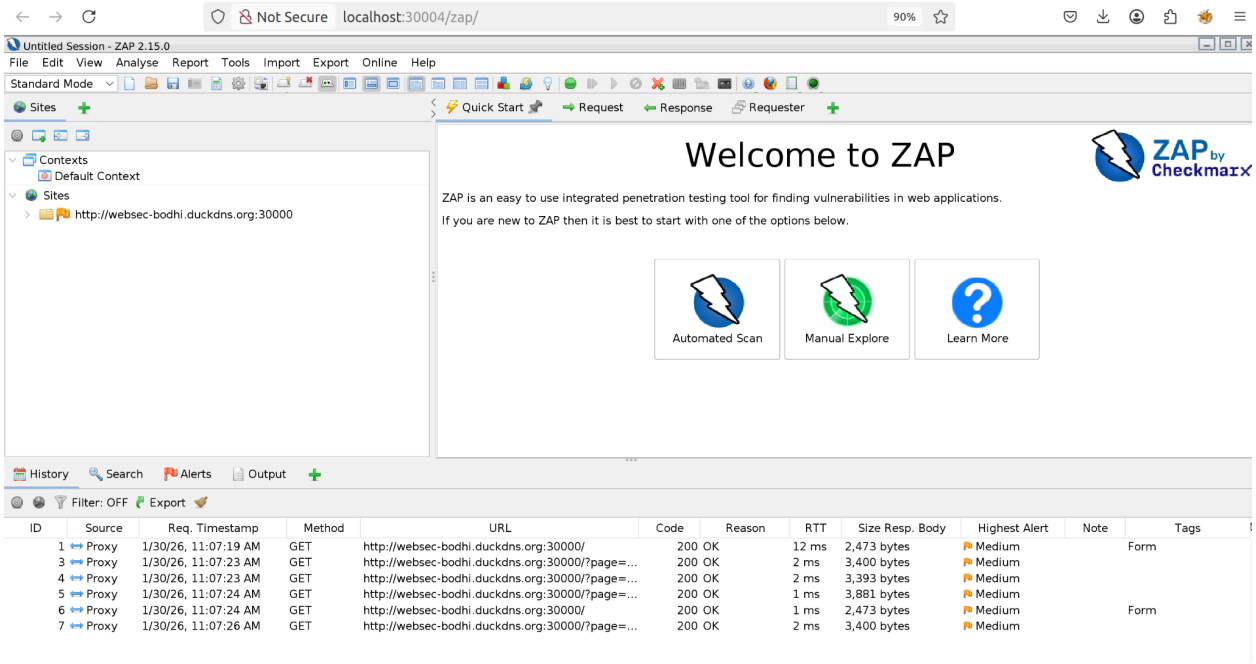
- By default ZAP converts any and all HTTP requests to HTTPS requests but our labs deal with http i.e. websites built on http for ease of setup and analysis. To avoid auto-conversion of protocols, we have to disable “HUD”. To do that go to our ZAP application, and click on the “Disable HUD” option as shown below. You may have to make ZAP window full screen to see the option. Hover over the icons, it will tell you if your selection is right.



Step-3: Check Overall Setup

If everything works, when you visit the local website i.e. "http://websec-bodhi.duckdns.org:30000/" as configured, you should see the traffic in ZAP window. Be sure HUD is disabled. You can use the broom icon to clear the screen




Not Secure
localhost:30004/zap/
90%
Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
http://websec-bodhi.duckdns.org:30000
Welcome to ZAP
ZAP by Checkmarx
ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.
If you are new to ZAP then it is best to start with one of the options below.
Automated Scan
Manual Explore
Learn More
History
Search
Alerts
Output
Filter: OFF
Export
ID Source Req. Timestamp Method URL Code Reason RTT Size Resp. Body Highest Alert Note Tags
1 Proxy 1/30/26, 11:07:19 AM GET http://websec-bodhi.duckdns.org:30000/ 200 OK 12 ms 2,473 bytes Medium Form
3 Proxy 1/30/26, 11:07:23 AM GET http://websec-bodhi.duckdns.org:30000/?page=... 200 OK 2 ms 3,400 bytes Medium
4 Proxy 1/30/26, 11:07:23 AM GET http://websec-bodhi.duckdns.org:30000/?page=... 200 OK 2 ms 3,393 bytes Medium
5 Proxy 1/30/26, 11:07:24 AM GET http://websec-bodhi.duckdns.org:30000/?page=... 200 OK 1 ms 3,881 bytes Medium
6 Proxy 1/30/26, 11:07:24 AM GET http://websec-bodhi.duckdns.org:30000/ 200 OK 1 ms 2,473 bytes Medium Form
7 Proxy 1/30/26, 11:07:26 AM GET http://websec-bodhi.duckdns.org:30000/?page=... 200 OK 2 ms 3,400 bytes Medium